

PostureOne

Cloud Security Posture Management Platform

Product Overview & Technical Capabilities

Andrea Ceresoni
April 2026 | Confidential

Executive Summary

PostureOne is a multi-tenant Cloud Security Posture Management (CSPM) platform that continuously scans cloud infrastructure, evaluates it against 179 security checks mapped to CIS Benchmarks v3.0, and delivers a prioritised action plan that tells security teams exactly what to fix first and why.

Unlike competitors that use proprietary black-box ML scoring (Wiz, Prisma Cloud) or produce flat, unprioritised finding lists (Prowler, ScoutSuite), PostureOne uses a transparent, YAML-driven priority formula that buyers can inspect, customise, and audit. This positions PostureOne uniquely at the intersection of open-source transparency and enterprise-grade triage.

The Problem

Every CSPM tool generates findings. A typical Azure subscription with 50-200 resources produces 60-200 failing controls on day one. Without triage, the user sees a flat list of red items with no indication of which ones matter, which ones are quick to fix, or which ones are internet-exposed. The result is predictable: the user opens the findings page, feels overwhelmed, closes it, and nothing gets fixed.

This is the core retention problem in CSPM: the tool produces signal, but the user cannot act on it because the signal-to-noise ratio is too low. Alerting without triage creates noise. Dashboards without prioritisation create confusion.

The Solution: Transparent Priority Triage

PostureOne automatically assigns every failing finding a priority bucket (P0 / P1 / P2 / P3) computed from three transparent axes:

Axis	Values	Source
Severity	high / medium / low	CIS benchmark definition
Effort	quick / moderate / refactor	YAML or inferred from control name
Exposure	internet / internal / none	YAML or inferred from resource type

The formula is a 3x3 matrix with an internet-exposure bump:

	Quick	Moderate	Refactor
High severity	P0	P1	P2

Medium severity	P1	P2	P3
Low severity	P2	P3	P3

Internet-exposed findings are bumped up one tier (capped at P0). The formula, the defaults, and the per-control overrides all live in control_mappings.yaml and are 100% inspectable and customisable per tenant.

Key Differentiators

Capability	PostureOne	Wiz / Prisma	Prowler / ScoutSuite
Priority triage	Transparent YAML formula	Black-box ML	None (flat list)
Remediation snippets	40 auto-filled (Terraform/Bicep/CLI)	Open/Closed	None
Secure Score projection	Current / after P0 / after P0+P1	Single score	None
Multi-tenant	First-class (MSSP-ready)	Enterprise add-on	No
Customisable per tenant	Full YAML override	No	N/A
Smart alerting	Only NEW P0/P1 (delta-based)	All findings	None
Scan drill-down	Delta vs previous scan	Yes	No
Pricing	Transparent tiers	Enterprise quotes	Free (no support)

Platform Capabilities

Security Checks

179 built-in security checks across 46 resource types, mapped to CIS Benchmarks v3.0:

Provider	Evaluators	YAML Controls	Resource Types
Azure	159	163	34
AWS	20	20	12
Total	179	183	46

Remediation Auto-Fill

40 controls ship with IaC remediation snippets in three formats (Terraform, Bicep, Azure CLI). Snippets are rendered with the actual asset's subscription ID, resource group, and resource name extracted from the ARM ID -- not generic placeholders. The user clicks Copy and pastes a ready-to-run command.

Smart Alerting

The finding.new_p0 event fires only when NEW P0 or P1 findings appear that were not present in the previous scan. This prevents alert fatigue. Delivered via Slack webhooks with priority emoji, Secure Score, delta counts, and action buttons linking directly to the findings page.

Additional Capabilities

Feature	Description
Scan drill-down	Priority breakdown + delta (new/fixed/unchanged) vs previous scan
Secure Score projection	Current / after P0 / after P0+P1 visualised as a segmented bar
Grouped remediation	19 remediation groups aggregate controls with the same fix
Bulk operations	Waive, assign, comment on findings at scale
PDF evidence packs	One-click export for audits and compliance reports
SSO/OIDC + MFA	Azure AD, Okta, Google Workspace + TOTP with backup codes
Custom RBAC	Granular roles beyond admin/viewer
Scheduled scans	Cron-based automated scanning via Celery Beat
Jira integration	Push findings as tickets
API keys	Programmatic access for CI/CD pipelines

Architecture Overview

Layer	Technology
Frontend	Next.js 16 (App Router), TypeScript, Tailwind CSS, Recharts
Backend	Python 3.12, FastAPI, SQLAlchemy 2.x (async), Pydantic v2
Database	PostgreSQL 16
Cache / Queue	Redis 7, Celery
Authentication	JWT (httpOnly cookies), bcrypt, TOTP/MFA, SSO/OIDC
Infrastructure	Docker Compose, Caddy (TLS), GitHub Actions CI/CD

Live Validation: IFO Production Tenant

The following results were captured on a live Azure tenant (6 assets, 86 evaluations) running the full 163-control scan against a real production subscription:

Priority Bucket	Count	Action Required
P0 -- Fix now	25	High severity + quick fix + internet-exposed
P1 -- Fix this week	29	Structural hardening
P2 -- Fix this sprint	8	Governance and resilience
P3 -- Best practice	3	Polish when time permits
Total failing	65	
Passing	21	

Secure Score: 24.4% (current) -> 53.5% (after fixing P0) -> 87.2% (after fixing P0 + P1). This demonstrates that one week of focused P0 remediation more than doubles the security posture.

Platform Security Posture

PostureOne underwent a comprehensive 4-reviewer parallel audit in April 2026 covering security, code quality, architecture, and product UX.

Area	Grade	Key Findings
------	-------	--------------

Security	A-	0 Critical, 0 High vulnerabilities. SSRF protection, JWT production-grade
Code Quality	B	1297 backend tests, evaluator batched, cursor pagination
Architecture	B+	Tenant isolation verified (322 JOIN checks), NOT NULL enforcement
Product	B	Triage layer unique in market, 40 auto-fill snippets, scan drill-down
Dependencies	A-	1 moderate Dependabot alert (from 11)

Pricing Tiers

Tier	Capabilities	Target Price Range
Scanner	Asset inventory, security checks, Secure Score, PDF export	5,000 - 15,000 EUR/year
Advisor	Scanner + Priority triage, auto-fill remediation, smart alerting, scan drill-down	40,000 - 100,000 EUR/year

The Advisor tier is unlocked by the Priority/Triage layer -- the same underlying checks, reframed as a ranked action plan with projected impact. This is a 3-5x price multiplier without adding any new scanning capability.